

MITRE ATT&CK Research Report

Intern ID	2124
Assigned Campaign	C0024 — SolarWinds Compromise
Assigned Software Range	S0240 – S0249 (10 Entries)
Submission Deadline	15 May 2026
Research Platform	https://attack.mitre.org/
Report Date	May 2026

PART 1: CAMPAIGN RESEARCH

Campaign C0024: SolarWinds Compromise

1.1 Campaign Overview

The SolarWinds Compromise (C0024) is one of the most sophisticated and consequential supply chain cyber operations ever documented. Conducted by APT29 (Cozy Bear), a threat group affiliated with Russia's Foreign Intelligence Service (SVR), the campaign was active from at least August 2019 and was publicly discovered in mid-December 2020. The attackers compromised SolarWinds' internal software build environment and used a custom implant (SUNSPOT) to inject malicious backdoor code (SUNBURST) into legitimate, digitally-signed Orion software updates distributed to approximately 18,000 customers worldwide.

Across industry reporting, the campaign was also referred to as StellarParticle (CrowdStrike), NOBELIUM (Microsoft), UNC2452 (FireEye/Mandiant), Dark Halo (Volexity), and SolarStorm (Palo Alto Unit 42). In April 2021, US and UK governments formally attributed the operation to Russia's SVR and APT29.

1.2 Threat Actor / Group Association

Attribute	Detail
Threat Group	APT29 (Cozy Bear / The Dukes)
Intelligence Service	Russia's Foreign Intelligence Service (SVR)
Industry Aliases	NOBELIUM, UNC2452, Dark Halo, SolarStorm, StellarParticle
Formal Attribution	US CISA, FBI, NSA and UK NCSC (April 2021)
Primary Motivation	Cyber espionage and strategic intelligence collection
Origin Nation	Russian Federation

1.3 Timeline of the Campaign

Date	Event
August 2019	APT29 gains initial access to SolarWinds build environment
October 2019	SUNSPOT implant first tested in the SolarWinds build pipeline
February 2020	SUNBURST backdoor first injected into Orion build process
Mar – Jun 2020	Trojanized Orion updates (v2019.4–2020.2.1) distributed to ~18,000 customers
May – Oct 2020	APT29 selectively activates SUNBURST on high-value targets; deploys TEARDROP/Cobalt Strike

Date	Event
December 8, 2020	FireEye discloses its own network breach and discovers SUNBURST
December 13, 2020	Microsoft, FireEye, and GoDaddy sinkhole the SUNBURST C2 domain (avsvmcloud.com)
December 13–14, 2020	SolarWinds and US government publicly disclose the compromise
Dec 2020 – Jan 2021	Full scope uncovered; SUNSPOT, Raindrop, GoldMax, Sibot, GoldFinder discovered
April 2021	US and UK formally attribute campaign to Russia SVR / APT29
January 2021	Last observed campaign activity

1.4 Objectives of Attack

- Intelligence collection from US government agencies including Treasury, Commerce, DHS, State Department, and DOD components
- Theft of sensitive emails, documents, and source code from technology and cybersecurity companies
- Long-term persistent covert access to high-value targets for sustained espionage
- Access to cybersecurity firms and their tools, methodologies, and threat intelligence (e.g., FireEye red team tools)
- Exploitation of trust relationships between SolarWinds and its customers to scale access across thousands of organizations

1.5 Targeted Sectors and Countries

Category	Details
Primary Country	United States (primary target)
Additional Countries	UK, Israel, UAE, Canada, Mexico, Belgium, Spain, Germany
Government	US Treasury, Commerce, DHS, State Dept, Pentagon, NNSA
Technology	Microsoft, Intel, Cisco, VMware, Qualys, Mimecast, SolarWinds
Cybersecurity	FireEye/Mandiant (compromised), Malwarebytes (targeted)
Consulting	Deloitte, KPMG, and other major professional services firms
Telecommunications	Multiple global telecommunications providers
Total Affected	~18,000 customers received trojanized Orion; smaller subset actively exploited

1.6 Attack Flow

- Stage 1 — Build Environment Compromise: APT29 compromised SolarWinds' internal software build environment. SUNSPOT malware was planted on the Orion build server to monitor build processes.
- Stage 2 — Supply Chain Injection: When SUNSPOT detected an Orion build process, it replaced a legitimate source file with a malicious version containing the SUNBURST backdoor, which was then compiled into the legitimate, signed SolarWinds DLL.
- Stage 3 — Distribution: Trojanized Orion Platform updates (versions 2019.4 through 2020.2.1) were cryptographically signed with SolarWinds' certificate and distributed via SolarWinds' standard software update mechanism.
- Stage 4 — Dormancy and Validation: After installation, SUNBURST remained dormant for 12–14 days. It validated the victim environment (checked for security tools, domain blacklists) before activating C2.
- Stage 5 — C2 via DNS: Active SUNBURST communicated via DNS to avsvmcloud[.]com, with victim hostnames encoded in DNS subdomain queries to receive commands encoded in DNS responses.
- Stage 6 — Selective Targeting: On validated high-value victims, APT29 deployed the TEARDROP loader, which loaded Cobalt Strike beacons for hands-on-keyboard operations.
- Stage 7 — Lateral Movement and Data Theft: Used forged SAML tokens, stolen credentials, and living-off-the-land tools to pivot laterally, access cloud resources (Azure AD, Office 365), and steal emails and source code.
- Stage 8 — Cleanup and Persistence: Removed backdoors after establishing alternative access via legitimate credentials and cloud account manipulation. Maintained long-term access through trusted relationship and identity-based techniques.

1.7 MITRE ATT&CK Techniques Used

Technique ID	Name	Details
T1195.002	Supply Chain Compromise: Software Supply Chain	Trojanized SolarWinds Orion update
T1553.002	Subvert Trust Controls: Code Signing	SUNBURST signed with SolarWinds certificate
T1606.002	Forge Web Credentials: SAML Tokens	Forged SAML tokens to impersonate users and bypass MFA
T1078	Valid Accounts	Compromised credentials for access and lateral movement
T1059.001	Command and Scripting Interpreter: PowerShell	PowerShell for discovery, execution, exfiltration
T1484.002	Domain Policy Modification: Trust Modification	Modified federation trust to accept forged SAML tokens
T1098.001	Account Manipulation: Additional Cloud Credentials	Added credentials to OAuth apps and Service Principals

Technique ID	Name	Details
T1560.001	Archive Collected Data: Archive via Utility	7-Zip to compress stolen emails before exfiltration
T1114.002	Email Collection: Remote Email Collection	Collected emails from Exchange/OWA servers
T1568	Dynamic Resolution	DNS-based C2 with randomly generated subdomains
T1070.006	Indicator Removal: Timestamp	Modified backdoor timestamps to match Windows files
T1003.006	OS Credential Dumping: DCSync	Replicated AD directory service data from domain controllers
T1558.003	Steal Kerberos Tickets: Kerberoasting	Obtained TGS tickets for offline cracking
T1539	Steal Web Session Cookie	Stole Chrome browser profile cookies
T1021.001	Remote Services: Remote Desktop Protocol	RDP from public-facing to internal servers
T1199	Trusted Relationship	Used compromised MSP accounts and Mimecast certificates

1.8 Real-World Incidents

- US Treasury Department: Senior Treasury officials' email systems accessed, including the acting undersecretary for international affairs and the Treasury Secretary's office staff.
- US Department of Homeland Security: Internal emails accessed; CISA itself was compromised — the very agency responsible for defending US government networks.
- FireEye: APT29 stole FireEye's proprietary red team offensive security tools. FireEye publicly disclosed the theft and released detection signatures to the community.
- Microsoft: APT29 downloaded source code for multiple Microsoft products. Microsoft confirmed no access to production services or customer data in their final investigation update.
- Mimecast: APT29 compromised a Mimecast-issued certificate used to authenticate connections between Mimecast tenants and Microsoft 365, enabling interception of customer traffic.
- SolarWinds: The company disclosed approximately 18,000 Orion customers installed trojanized updates during the active distribution window (March–June 2020).

1.9 Detection Opportunities

- DNS Monitoring: SUNBURST encoded victim hostnames in DNS subdomain queries to avsvmcloud[.]com. Anomalous DNS patterns with encoded hostnames were a primary detection vector.
- SAML Token Analysis: Detect SAML tokens signed by unexpected certificates or tokens without corresponding authentication events in Azure AD and ADFS logs.

- SolarWinds Orion Behavior: Monitor Orion processes for unexpected PowerShell spawning, network connections to external hosts, and unusual child processes.
- Cloud Audit Logs: Review Azure AD and Office 365 audit logs for new Service Principal creation, OAuth permission grants, new device registrations, and unusual mail export requests.
- Lateral Movement Indicators: Monitor for DCSync activity, Kerberoasting (TGS requests), and living-off-the-land enumeration commands in unexpected contexts.
- Timestamping Detection: Identify files with metadata timestamps inconsistent with their actual filesystem creation or modification times.
- SUNBURST Hash IOCs: Known file hashes for SolarWinds.Orion.Core.BusinessLayer.dll versions containing the SUNBURST backdoor code.

1.10 Defensive Recommendations

- Software Supply Chain Security: Implement build environment monitoring, code integrity verification, reproducible builds, and software composition analysis (SCA) for all externally sourced software.
- Zero Trust Architecture: Enforce least-privilege access; verify all traffic; do not implicitly trust internal network communications; segment build and distribution systems.
- Phishing-Resistant MFA: Deploy FIDO2/hardware token MFA; monitor for SAML token forgery and MFA bypass via cookie theft.
- Cloud Identity Monitoring: Continuously audit Azure AD/O365 for new service principals, OAuth applications, permission grants, federation trust changes, and delegated administrative permissions.
- Privileged Access Workstations (PAWs): Dedicated hardened workstations for all administrative tasks including cloud and identity management.
- Network Segmentation: Isolate build pipelines, software distribution infrastructure, and privileged management systems from corporate networks.
- Vendor Risk Management: Treat all software vendors as potential attack vectors; sandbox-test updates before production deployment; monitor vendor security advisories.
- Threat Intelligence Integration: Subscribe to CISA, NCSC, and industry threat intelligence feeds; act promptly on nation-state supply chain attack advisories.

PART 2: SOFTWARE RESEARCH

The following section presents detailed technical research for each of the 10 assigned MITRE ATT&CK software entries (S0240 through S0249).

Software 1: S0240 — ROKRAT

2.1.1 Name & Type

Field	Value
MITRE ATT&CK ID	S0240
Name	ROKRAT
Type	Malware (Remote Access Trojan)
Supported Platforms	Windows
Threat Actor	APT37 (ScarCruft / InkySquid — North Korea)
ATT&CK Reference	https://attack.mitre.org/software/S0240/

2.1.2 Description

ROKRAT is a cloud-based RAT developed and used exclusively by APT37, a North Korean state-sponsored threat group. Active since at least 2016, ROKRAT targets South Korean government agencies, journalists, diplomatic organizations, and human rights groups. It is notable for abusing legitimate cloud platforms (Dropbox, Twitter, Yandex, OneDrive, pCloud) for C2 to blend malicious traffic with normal network usage. ROKRAT has both C-based and VBA-based variants and supports a wide range of espionage functions including keylogging, screen capture, audio recording, and credential theft.

2.1.3 ATT&CK Techniques Used

Technique ID	Name	Description
T1071.001	Application Layer Protocol: Web Protocols	HTTP/HTTPS C2 via cloud platforms
T1567.002	Exfiltration Over Web Service: Cloud Storage	Exfiltrates to pCloud/Dropbox
T1102.002	Web Service: Bidirectional Communication	Uses Twitter, Yandex, Dropbox for C2
T1056.001	Input Capture: Keylogging	Captures keystrokes via SetWindowsHookEx
T1113	Screen Capture	Captures screenshots using GDI32

Technique ID	Name	Description
T1123	Audio Capture	Eavesdropping via microphone access
T1115	Clipboard Data	Extracts clipboard contents
T1055	Process Injection	Injects shellcode into Notepad.exe
T1027	Obfuscated Files or Information	Encrypts data with RSA public key
T1497.001	Virtualization/Sandbox Evasion: System Checks	Checks for VMware/sandbox artifacts
T1480.001	Execution Guardrails: Environmental Keying	Relies on victim hostname for activation
T1566.001	Phishing: Spearphishing Attachment	Delivered via malicious HWP/Word docs
T1555.003	Credentials from Web Browsers	Queries browser SQLite DBs for credentials
T1112	Modify Registry	Modifies HKCU Office key to bypass VBOM
T1622	Debugger Evasion	Checks for debugging tools before running

2.1.4 Execution Method

Delivered via spearphishing emails containing malicious Hangul Office (.HWP) or Microsoft Word documents. Upon user execution, ROKRAT shellcode is injected into legitimate processes such as Notepad.exe using VirtualAlloc, WriteProcessMemory, and CreateRemoteThread APIs. It uses environmental keying tied to the victim hostname to prevent analysis in sandboxes.

2.1.5 Persistence Techniques

ROKRAT primarily functions as an in-memory implant. It uses environmental keying (hostname-based) rather than conventional persistence, though some variants achieve persistence via registry Run keys.

2.1.6 Privilege Escalation

Process injection into legitimate system processes allows operation under their security context, potentially gaining elevated privileges.

2.1.7 Defense Evasion

Debugger and sandbox evasion via API checks and VMware artifact detection; RSA encryption of exfiltrated data; use of legitimate cloud platforms for C2 traffic blending; environmental keying prevents execution outside target environment.

2.1.8 Credential Access

Steals credentials from web browser SQLite databases (Chrome, Firefox) and Windows Credential Manager (Windows Vault API).

2.1.9 Discovery Techniques

Application window discovery (GetForegroundWindow), file and directory enumeration, running process listing, system information gathering (hostname, OS version), and user/owner identification.

2.1.10 Lateral Movement

Not directly documented for lateral movement; focuses primarily on data collection. Process injection into legitimate binaries may facilitate movement within host context.

2.1.11 Command & Control (C2)

Uses legitimate cloud platforms including Dropbox, Twitter, Yandex, OneDrive, and pCloud for bidirectional C2 communication via HTTP/HTTPS, making traffic appear as normal cloud service usage.

2.1.12 Exfiltration

Data is encrypted with an RSA public key and exfiltrated to cloud storage services (pCloud, Dropbox) or sent back over the established C2 channel.

2.1.13 Impact Analysis

Data theft targeting South Korean government, military, and civilian organizations; audio/video/keystroke surveillance; credential harvesting; full remote control of victim systems over extended periods.

2.1.14 Indicators of Compromise (IOCs)

C2 via cloud platform API calls; VMware artifact checks; registry modifications at HKCU\Software\Microsoft\Office; use of SetWindowsHookEx and GetForegroundWindow APIs; RSA-encrypted network traffic; Notepad.exe with injected shellcode.

2.1.15 Detection & Mitigation

Detection: Monitor for unusual API calls (SetWindowsHookEx, GetKeyNameText); cloud storage API calls from non-browser processes; process injection into Notepad.exe; suspicious Office macro execution; HWP document spawning unexpected child processes.

Mitigation: Block macros in Office documents from the internet (Group Policy); deploy cloud access security broker (CASB); monitor for process injection; restrict cloud storage access from sensitive endpoints; deploy behaviour-based EDR solutions.

2.1.16 References & Sources

- <https://attack.mitre.org/software/S0240/>
- <https://blog.talosintelligence.com/2017/04/introducing-rokrat.html>
- <https://www.volexity.com/blog/2021/08/24/north-korean-bluelight-special-inkysquid-deploys-rokrat/>

Software 2: S0241 — RATANKBA

2.2.1 Name & Type

Field	Value
MITRE ATT&CK ID	S0241
Name	RATANKBA
Type	Malware (Remote Controller Tool)
Supported Platforms	Windows
Threat Actor	Lazarus Group (Hidden Cobra — North Korea)
ATT&CK Reference	https://attack.mitre.org/software/S0241/

2.2.2 Description

RATANKBA is a remote controller tool used by the North Korean Lazarus Group in attacks primarily targeting financial institutions across Poland, Mexico, Uruguay, the UK, and Chile. It also targeted organizations in telecommunications, management consulting, IT, insurance, aviation, and education. RATANKBA features a GUI allowing attackers to issue jobs to infected machines. Both a traditional PE variant and an in-memory PowerShell script variant have been observed in the wild.

2.2.3 ATT&CK Techniques Used

Technique ID	Name	Description
T1059.001	Command and Scripting Interpreter: PowerShell	PowerShell in-memory variant
T1059.003	Command and Scripting Interpreter: Windows Command Shell	cmd.exe for command execution
T1055.001	Process Injection: DLL Injection	Reflective DLL injection by PID
T1087.001	Account Discovery: Local Account	Uses 'net user' command
T1018	Remote System Discovery	Runs 'net view /domain' and 'net view'
T1057	Process Discovery	Lists running processes via tasklist
T1012	Query Registry	Queries HKCU Internet Settings
T1082	System Information Discovery	Gathers OS version, architecture
T1016	System Network Configuration Discovery	Gathers IP via 'ipconfig -all'
T1049	System Network Connections Discovery	Uses 'netstat -ano'

Technique ID	Name	Description
T1033	System Owner/User Discovery	Runs 'whoami' and 'query user'
T1007	System Service Discovery	Uses 'tasklist /svc'
T1047	Windows Management Instrumentation	Uses WMI for process monitoring
T1105	Ingress Tool Transfer	Uploads and downloads files to/from C2
T1071.001	Application Layer Protocol: Web Protocols	HTTP/HTTPS C2 communications

2.2.4 Execution Method

Distributed via watering hole attacks on compromised banking-related websites and via spearphishing. The PowerShell variant executes entirely in memory to avoid disk artifacts. The PE variant performs reflective DLL injection into a target process identified by PID.

2.2.5 Persistence Techniques

Limited direct persistence in the documented variants; relies on dropper/loader mechanisms for re-infection and watering hole compromise for persistent access to victim networks.

2.2.6 Privilege Escalation

Reflective DLL injection into elevated processes to gain higher privilege context; PowerShell execution may be elevated depending on context.

2.2.7 Defense Evasion

PowerShell-based in-memory variant leaves minimal disk artifacts; HTTP/HTTPS traffic blends with normal web traffic; GUI controller runs on attacker-side infrastructure.

2.2.8 Credential Access

Not directly documented for credential dumping; extensive network discovery data collected is useful for planning credential attacks.

2.2.9 Discovery Techniques

Comprehensive enumeration: local accounts (net user), domain systems (net view), processes (tasklist /svc), network configuration (ipconfig), active connections (netstat -ano), registry queries, system info, and user identity.

2.2.10 Lateral Movement

Remote system discovery via net view enables lateral movement planning; reflective DLL injection into remote PIDs facilitates movement across systems.

2.2.11 Command & Control (C2)

HTTP/HTTPS communication to attacker-controlled C2 servers. A GUI-based controller on the attacker side allows issuing jobs to infected machines interactively.

2.2.12 Exfiltration

Collected data uploaded to C2 server via HTTP/HTTPS over the established C2 channel.

2.2.13 Impact Analysis

Financial sector targeting enabling SWIFT transaction fraud; comprehensive reconnaissance supporting larger Lazarus Group intrusion campaigns including destructive attacks.

2.2.14 Indicators of Compromise (IOCs)

Reflective DLL injection events; cmd.exe spawning 'net user', 'net view', 'whoami', 'tasklist /svc', 'netstat -ano', 'ipconfig -all'; PowerShell in-memory execution; WMI process monitoring; HTTP beaconing to unknown hosts.

2.2.15 Detection & Mitigation

Detection: Monitor for suspicious PowerShell execution (encoded/in-memory); reflective DLL injection indicators; unusual network enumeration command sequences; HTTP beaconing patterns; WMI abuse.

Mitigation: PowerShell Constrained Language Mode and logging; block macros; application whitelisting; network segmentation; monitor WMI activity; deploy EDR with memory scanning.

2.2.16 References & Sources

- <https://attack.mitre.org/software/S0241/>
- https://www.trendmicro.com/en_us/research/17/b/ratankba-watering-holes-against-enterprises.html

Software 3: S0242 — SynAck

2.3.1 Name & Type

Field	Value
MITRE ATT&CK ID	S0242
Name	SynAck
Type	Malware (Targeted Ransomware)
Supported Platforms	Windows
Threat Actor	Unattributed financially-motivated threat actors
ATT&CK Reference	https://attack.mitre.org/software/S0242/

2.3.2 Description

SynAck is a sophisticated targeted ransomware observed since 2017 and notable for being the first publicly documented ransomware to use the Process Doppelganging technique for defense evasion. It was deployed in targeted attacks against high-value victims in the United States, Kuwait, Germany, and Iran. SynAck employs multiple anti-analysis and sandbox evasion techniques, and encrypts files on local drives and accessible network shares.

2.3.3 ATT&CK Techniques Used

Technique ID	Name	Description
T1055.013	Process Injection: Process Doppelganging	First ransomware to use this technique
T1486	Data Encrypted for Impact	Encrypts files on local and network shares
T1562.001	Impair Defenses: Disable or Modify Tools	Terminates security-related processes
T1070.004	Indicator Removal: File Deletion	Deletes itself post-execution
T1497	Virtualization/Sandbox Evasion	Checks directory hash of execution path
T1083	File and Directory Discovery	Enumerates files for encryption
T1135	Network Share Discovery	Discovers and encrypts network shares
T1490	Inhibit System Recovery	Deletes Volume Shadow Copies
T1059.003	Command and Scripting Interpreter: Windows Command Shell	Uses cmd.exe
T1027	Obfuscated Files or Information	Obfuscated strings and code

Technique ID	Name	Description
T1112	Modify Registry	Modifies registry for execution flow
T1547.001	Boot or Logon Autostart Execution: Registry Run Keys	Persistence via registry
T1003	OS Credential Dumping	Can dump credentials from memory
T1036	Masquerading	Disguises via Doppelganging technique

2.3.4 Execution Method

Uses Process Doppelganging to inject malicious code into a legitimate Windows process using NTFS transactions. The transaction is rolled back so the malicious file never appears on disk, bypassing most AV and sandbox detection. Checks the directory hash of its execution path for sandbox detection.

2.3.5 Persistence Techniques

Achieves persistence via Registry Run Keys. Typically deployed by initial access brokers after prior compromise of high-value targets.

2.3.6 Privilege Escalation

Runs under user-level privileges but targets system-wide encryption including network shares. Some variants attempt UAC bypass.

2.3.7 Defense Evasion

Process Doppelganging (primary evasion); directory hash check of execution path for sandbox detection; obfuscated strings; termination of AV/security software processes before encryption.

2.3.8 Credential Access

Documented credential dumping capability from memory to facilitate lateral movement to maximize encryption scope.

2.3.9 Discovery Techniques

Local file system enumeration and network share discovery to identify all encryption targets.

2.3.10 Lateral Movement

Network share discovery and encryption; credential dumping enables potential lateral movement to maximize impact.

2.3.11 Command & Control (C2)

Primarily offline operation after deployment; limited C2 activity documented. Focus is on encryption impact rather than remote control.

2.3.12 Exfiltration

Primarily impact-focused (encryption); some variants may exfiltrate data prior to encryption for double extortion leverage.

2.3.13 Impact Analysis

Encrypts all discoverable files on local drives and network shares; deletes Volume Shadow Copies to prevent recovery; demands ransom for decryption key. High-value targeting maximizes leverage and ransom demands.

2.3.14 Indicators of Compromise (IOCs)

NTFS transaction anomalies; ransom note files (.txt);. synack extension on encrypted files; vssadmin delete shadows command execution; termination of backup/database processes; self-deletion of dropper.

2.3.15 Detection & Mitigation

Detection: Monitor for NTFS transaction-based anomalies in process creation; Volume Shadow Copy deletion commands; mass file modification/encryption events; termination of security software processes; unusual registry Run key creation.

Mitigation: Maintain isolated offline backups; enable Windows Controlled Folder Access; behavior-based EDR; network segmentation to limit share access; patch and vulnerability management; incident response planning.

2.3.16 References & Sources

- <https://attack.mitre.org/software/S0242/>
- <https://securelist.com/synack-targeted-ransomware-uses-the-doppelganging-technique/85431/>

Software 4: S0243 — DealersChoice

2.4.1 Name & Type

Field	Value
MITRE ATT&CK ID	S0243
Name	DealersChoice
Type	Malware (Flash Exploitation Framework)
Supported Platforms	Windows
Threat Actor	APT28 (Fancy Bear / Sofacy — Russia GRU)
ATT&CK Reference	https://attack.mitre.org/software/S0243/

2.4.2 Description

DealersChoice is an Adobe Flash Player exploitation framework used by Russian military intelligence group APT28 (Fancy Bear). First observed in October 2016, it generates malicious Office documents embedding obfuscated Flash SWF objects that exploit vulnerabilities in Adobe Flash Player to execute shellcode. DealersChoice had two variants: Variant A checks for specific Flash versions locally, while Variant B contacts a C2 server to dynamically retrieve exploit payloads — significantly reducing static detection signatures.

2.4.3 ATT&CK Techniques Used

Technique ID	Name	Description
T1203	Exploitation for Client Execution	Exploits Flash Player vulnerabilities (e.g., CVE-2016-7855)
T1566.001	Phishing: Spearphishing Attachment	Delivered via malicious Office/RTF documents
T1204.002	User Execution: Malicious File	Requires user to open malicious document
T1027	Obfuscated Files or Information	Heavily obfuscated Flash ActionScript
T1071.001	Application Layer Protocol: Web Protocols	Variant B contacts C2 for exploit retrieval
T1105	Ingress Tool Transfer	Downloads secondary payloads post-exploitation
T1082	System Information Discovery	Checks Flash version and system environment
T1497	Virtualization/Sandbox Evasion	Environment checks prior to exploitation

Technique ID	Name	Description
T1059	Command and Scripting Interpreter	Executes shellcode upon successful exploitation

2.4.4 Execution Method

Embeds malicious Flash SWF objects in RTF or Office documents distributed via spearphishing. Upon opening, the ActionScript exploits Flash vulnerabilities (CVE-2016-7855) to execute shellcode. Typically delivers EVILTOSS or CHOPSTICK second-stage backdoors.

2.4.5 Persistence Techniques

DealersChoice is not persistent itself; serves as initial access/execution mechanism to deploy persistent second-stage backdoors (EVILTOSS, CHOPSTICK/X-Agent).

2.4.6 Privilege Escalation

Exploits Flash vulnerabilities to achieve code execution within the context of the victim application, potentially inheriting its privilege level.

2.4.7 Defense Evasion

Heavily obfuscated ActionScript evades static AV; environment and Flash version checking; Variant B retrieves exploits dynamically from C2, reducing static signatures; legitimate Office document as delivery vehicle.

2.4.8 Credential Access

Not directly; enables deployment of credential-stealing second-stage tools (EVILTOSS has credential theft capability).

2.4.9 Discovery Techniques

Checks Adobe Flash Player version and system environment for targeting decisions and sandbox detection.

2.4.10 Lateral Movement

Not directly; serves as initial access vector enabling deployment of lateral movement tools.

2.4.11 Command & Control (C2)

Variant B dynamically contacts attacker C2 server to retrieve the Flash exploit payload, allowing real-time exploit updates and avoiding static detection.

2.4.12 Exfiltration

Not directly; enables deployment of full-featured exfiltration backdoors.

2.4.13 Impact Analysis

Initial compromise enabling APT28 espionage campaigns; targets NATO governments, defense contractors, political organizations, and media. Enables persistent access for intelligence collection.

2.4.14 Indicators of Compromise (IOCs)

Office/RTF documents with embedded Flash objects; SWF files with obfuscated ActionScript; network callbacks to APT28 C2 infrastructure; EVILTOSS or CHOPSTICK artifacts post-exploitation; Flash crash patterns.

2.4.15 Detection & Mitigation

Detection: Detect Flash content embedded in Office documents; Flash exploitation crash telemetry; C2 callback network detection post-Flash exploitation; shellcode execution pattern detection via EDR.

Mitigation: Disable Adobe Flash Player (EOL December 2020 — should be uninstalled); block Flash in Office via Group Policy; use Protected View for email attachments; deploy Windows Defender Exploit Guard / EMET.

2.4.16 References & Sources

- <https://attack.mitre.org/software/S0243/>
- <https://researchcenter.paloaltonetworks.com/2016/10/unit42-dealerschoice-sofacys-flash-player-exploit-platform/>

Software 5: S0244 — Comnie

2.5.1 Name & Type

Field	Value
MITRE ATT&CK ID	S0244
Name	Comnie
Type	Malware (Remote Access Backdoor)
Supported Platforms	Windows
Threat Actor	Unattributed — East Asian targeting (observed 2018)
ATT&CK Reference	https://attack.mitre.org/software/S0244/

2.5.2 Description

Comnie is a remote backdoor used in cyber espionage campaigns targeting organizations in Japan, South Korea, and Taiwan. Documented by Palo Alto Unit 42 in 2018, Comnie is notable for using GitHub, Twitter, and Tumblr as dead drop resolvers to obtain its actual C2 server addresses. This technique renders IP/domain blacklisting ineffective since the C2 infrastructure is hidden behind legitimate, trusted web platforms. Comnie supports comprehensive remote access capabilities.

2.5.3 ATT&CK Techniques Used

Technique ID	Name	Description
T1102.001	Web Service: Dead Drop Resolver	Uses GitHub, Twitter, Tumblr to resolve C2
T1071.001	Application Layer Protocol: Web Protocols	HTTP for actual C2 communication
T1059.003	Command and Scripting Interpreter: Windows Command Shell	cmd.exe for command execution
T1082	System Information Discovery	Collects system information
T1083	File and Directory Discovery	Enumerates files and directories
T1105	Ingress Tool Transfer	Downloads additional files and tools
T1547.001	Boot or Logon Autostart Execution: Registry Run Keys	Persistence via Run keys
T1027	Obfuscated Files or Information	Obfuscated code to evade detection
T1057	Process Discovery	Lists running processes
T1016	System Network Configuration Discovery	Gathers network configuration

Technique ID	Name	Description
T1033	System Owner/User Discovery	Identifies current user
T1560	Archive Collected Data	Archives data before exfiltration
T1041	Exfiltration Over C2 Channel	Sends data back via C2

2.5.4 Execution Method

Delivered via spearphishing documents or drive-by compromise. After execution, Connie resolves its C2 IP by parsing encoded content posted to legitimate web platforms (GitHub repositories, Twitter profiles, Tumblr posts), then communicates with the resolved C2 server.

2.5.5 Persistence Techniques

Achieves persistence via Windows Registry Run keys (HKCU\HKLM\Software\Microsoft\Windows\CurrentVersion\Run) to survive system reboots.

2.5.6 Privilege Escalation

Operates under user context; does not include documented built-in privilege escalation techniques.

2.5.7 Defense Evasion

Dead drop resolver technique makes static C2 IP/domain blacklisting ineffective; obfuscated code; uses legitimate web service traffic making it difficult to distinguish from normal user browsing.

2.5.8 Credential Access

Not directly documented for credential access; reconnaissance data collected supports planning of follow-on credential attacks.

2.5.9 Discovery Techniques

System information collection, file and directory enumeration, process listing, network configuration discovery, and current user identification.

2.5.10 Lateral Movement

Not directly documented; extensive reconnaissance capabilities facilitate lateral movement planning by operators.

2.5.11 Command & Control (C2)

Uses legitimate web platforms (GitHub, Twitter, Tumblr) as dead drop resolvers containing encoded C2 IP addresses. Actual C2 traffic goes to a separate server via HTTP.

2.5.12 Exfiltration

Collects and archives data, then exfiltrates via HTTP over the C2 channel.

2.5.13 Impact Analysis

Cyber espionage targeting East Asian technology and government organizations; enables sustained long-term intelligence collection.

2.5.14 Indicators of Compromise (IOCs)

HTTP requests to GitHub/Twitter/Tumblr for encoded data parsing by unexpected processes; registry Run key creation; outbound HTTP to resolved C2 IPs; cmd.exe spawning from non-standard parent processes; data archiving activity.

2.5.15 Detection & Mitigation

Detection: Monitor social media/code hosting API calls from non-browser processes; registry Run key modifications; anomalous cmd.exe execution chains; data staging and exfiltration behavior patterns.

Mitigation: Web content filtering (restrict social media API access from non-user processes); registry monitoring; network traffic inspection; email security; behavior-based EDR.

2.5.16 References & Sources

- <https://attack.mitre.org/software/S0244/>
- <https://unit42.paloaltonetworks.com/unit42-comnie-continues-target-organizations-east-asia/>

Software 6: S0245 — BADCALL

2.6.1 Name & Type

Field	Value
MITRE ATT&CK ID	S0245
Name	BADCALL
Type	Malware (Trojan Backdoor)
Supported Platforms	Windows
Threat Actor	Lazarus Group (Hidden Cobra — North Korea)
ATT&CK Reference	https://attack.mitre.org/software/S0245/

2.6.2 Description

BADCALL is a Trojan backdoor used by North Korea's Lazarus Group (referred to as Hidden Cobra by US-CERT). Publicly disclosed by DHS and FBI as part of a Hidden Cobra advisory, BADCALL masquerades as a Flash Player update installer to trick users into executing it. It establishes persistent remote access via SSL-encrypted communications and raw TCP sockets, providing Lazarus Group operators with a stealthy foothold for further operations.

2.6.3 ATT&CK Techniques Used

Technique ID	Name	Description
T1071.001	Application Layer Protocol: Web Protocols	SSL/HTTPS for C2 communication
T1573.001	Encrypted Channel: Symmetric Cryptography	Encrypted C2 traffic
T1036	Masquerading	Disguises as Adobe Flash Player update
T1059.003	Command and Scripting Interpreter: Windows Command Shell	Shell command execution
T1105	Ingress Tool Transfer	Downloads additional tools and payloads
T1082	System Information Discovery	Collects system information
T1083	File and Directory Discovery	File enumeration capability
T1095	Non-Application Layer Protocol	Communicates over raw TCP sockets
T1547.001	Boot or Logon Autostart Execution: Registry Run Keys	Persistence via registry

Technique ID	Name	Description
T1543.003	Create or Modify System Process: Windows Service	May install as a Windows service
T1562.001	Impair Defenses: Disable or Modify Tools	Can disable security software
T1033	System Owner/User Discovery	Identifies system user
T1016	System Network Configuration Discovery	Gathers network configuration

2.6.4 Execution Method

Distributed disguised as a fake Adobe Flash Player update executable. Upon execution, installs itself for persistence (registry Run key or Windows service), then establishes encrypted C2 communication to attacker-controlled infrastructure.

2.6.5 Persistence Techniques

Windows Registry Run keys and/or Windows Service installation for persistence across reboots.

2.6.6 Privilege Escalation

Service installation may require administrative privileges; can request UAC bypass in some variants. Registry persistence works at user level.

2.6.7 Defense Evasion

Masquerades as legitimate Flash Player update; SSL/HTTPS-encrypted C2 traffic; raw TCP socket communications blend with normal traffic patterns.

2.6.8 Credential Access

Not directly documented; serves as a remote access platform enabling operator-directed credential theft using additional tools.

2.6.9 Discovery Techniques

System information collection, file enumeration, network configuration, and user identity discovery.

2.6.10 Lateral Movement

Provides full remote shell capability enabling manual lateral movement by Lazarus Group operators.

2.6.11 Command & Control (C2)

SSL/HTTPS and raw TCP socket communications to attacker-controlled C2 servers. Encrypted channel complicates traffic inspection and detection.

2.6.12 Exfiltration

Operator-directed manual exfiltration via the established backdoor communication channel.

2.6.13 Impact Analysis

Persistent covert remote access for Lazarus Group operations including espionage, data theft, financial fraud preparation, and staging for destructive attacks.

2.6.14 Indicators of Compromise (IOCs)

Fake Flash Player installer executables (verify digital signature); SSL connections to unusual IPs on non-standard ports; new Windows services with suspicious names/paths; registry Run key creation pointing to non-standard paths; raw TCP connections.

2.6.15 Detection & Mitigation

Detection: Flag Flash installer executables failing digital signature verification; monitor unexpected service creation; SSL traffic to unknown IPs; registry Run key modifications by non-system processes; raw TCP connections to unusual ports.

Mitigation: Remove and block Flash (EOL product); application whitelisting; verify software update authenticity; network filtering and IPS; EDR deployment; monitor service creation and registry changes.

2.6.16 References & Sources

- <https://attack.mitre.org/software/S0245/>
- <https://www.cisa.gov/news-events/alerts/2017/11/14/hidden-cobra-north-koreans-ddos-botnet-infrastructure>

Software 7: S0246 — HARDRAIN

2.7.1 Name & Type

Field	Value
MITRE ATT&CK ID	S0246
Name	HARDRAIN
Type	Malware (Trojan / Reverse Proxy Tool)
Supported Platforms	Windows
Threat Actor	Lazarus Group (Hidden Cobra — North Korea)
ATT&CK Reference	https://attack.mitre.org/software/S0246/

2.7.2 Description

HARDRAIN is a Trojan and reverse proxy tool used by the North Korean Lazarus Group, publicly disclosed by DHS and FBI in a Hidden Cobra advisory in 2018. HARDRAIN establishes persistent covert communication channels by functioning as a reverse proxy, tunneling traffic between compromised endpoints and attacker C2 infrastructure. It masquerades as a legitimate executable to avoid initial detection. HARDRAIN provides Lazarus Group operators with persistent, covert access to victim networks.

2.7.3 ATT&CK Techniques Used

Technique ID	Name	Description
T1090.002	Proxy: External Proxy	Reverse proxy functionality for covert C2
T1071.001	Application Layer Protocol: Web Protocols	HTTP/HTTPS communication
T1036.005	Masquerading: Match Legitimate Resource Name or Location	Masquerades as legitimate executables
T1547.001	Boot or Logon Autostart Execution: Registry Run Keys	Registry persistence
T1543.003	Create or Modify System Process: Windows Service	May install as Windows service
T1059.003	Command and Scripting Interpreter: Windows Command Shell	Command execution capability
T1105	Ingress Tool Transfer	Downloads additional files and payloads
T1082	System Information Discovery	Gathers system information
T1095	Non-Application Layer Protocol	Raw TCP socket communications

Technique ID	Name	Description
T1573	Encrypted Channel	Encrypts C2 communications
T1083	File and Directory Discovery	File enumeration capability

2.7.4 Execution Method

Deployed as a Windows executable masquerading as a legitimate file (typically with a plausible Windows system file name). Installs persistence mechanism and sets up reverse proxy tunneling to connect back to C2 infrastructure.

2.7.5 Persistence Techniques

Windows Registry Run keys; installation as a Windows Service for system-level persistence.

2.7.6 Privilege Escalation

User-level execution for registry persistence; administrative privileges needed for service installation.

2.7.7 Defense Evasion

Masquerades as legitimate Windows executable; encrypted communications; mimics normal HTTP/S traffic patterns making C2 difficult to detect.

2.7.8 Credential Access

Not directly documented; provides remote access enabling operator-directed credential theft via additional tools.

2.7.9 Discovery Techniques

System information collection; network configuration discovery; file system enumeration.

2.7.10 Lateral Movement

Reverse proxy capability creates covert tunnelled communication channels supporting lateral movement operations. Enables pivoting through compromised hosts.

2.7.11 Command & Control (C2)

Functions as a reverse proxy, creating tunnelled connections between compromised host and C2 server. Uses HTTP/HTTPS and raw TCP with encrypted communications. Difficult to block without deep packet inspection.

2.7.12 Exfiltration

Enables operator-directed exfiltration via the established reverse proxy tunnel.

2.7.13 Impact Analysis

Covert, persistent access to victim networks for long-term espionage, intelligence collection, and preparation for further Lazarus Group operations (financial theft, destructive attacks).

2.7.14 Indicators of Compromise (IOCs)

Reverse proxy network traffic patterns; registry Run key creation; masqueraded process names in unusual paths; encrypted TCP connections on unexpected ports; DHS/FBI-published HARDRAIN hash indicators.

2.7.15 Detection & Mitigation

Detection: Monitor for reverse proxy network characteristics; anomalous registry Run key additions; process execution from unexpected paths; encrypted traffic to unknown IPs; correlate with published HARDRAIN IOCs.

Mitigation: Network monitoring for proxy-like traffic patterns; application whitelisting; registry monitoring; deploy EDR solutions; block known HARDRAIN C2 indicators; network segmentation.

2.7.16 References & Sources

- <https://attack.mitre.org/software/S0246/>
- <https://www.cisa.gov/news-events/alerts/2018/05/29/hidden-cobra-joanap-backdoor-trojan-and-brambul-server-message-block>

Software 8: S0247 — NavRAT

2.8.1 Name & Type

Field	Value
MITRE ATT&CK ID	S0247
Name	NavRAT
Type	Malware (Remote Access Trojan)
Supported Platforms	Windows
Threat Actor	APT37 (ScarCruft — North Korea)
ATT&CK Reference	https://attack.mitre.org/software/S0247/

2.8.2 Description

NavRAT is a Remote Access Trojan used by North Korean APT37 (ScarCruft) in targeted campaigns against South Korean individuals and organizations. Documented by Cisco Talos in May 2018, NavRAT was distributed via malicious Hangul Word Processor (HWP) documents themed around the inter-Korean summit. It is notable for using the South Korean Naver web portal's email service for bidirectional C2 communications, making malicious traffic virtually indistinguishable from legitimate email activity for South Korean victims.

2.8.3 ATT&CK Techniques Used

Technique ID	Name	Description
T1102.002	Web Service: Bidirectional Communication	Uses Naver email accounts for C2
T1566.001	Phishing: Spearphishing Attachment	Distributed via malicious HWP documents
T1203	Exploitation for Client Execution	Exploits HWP EPS vulnerabilities
T1059.003	Command and Scripting Interpreter: Windows Command Shell	Commands via cmd.exe
T1082	System Information Discovery	Gathers system information
T1083	File and Directory Discovery	Enumerates files and directories
T1057	Process Discovery	Lists running processes
T1113	Screen Capture	Captures screenshots of victim desktop
T1105	Ingress Tool Transfer	Downloads additional tools from C2
T1041	Exfiltration Over C2 Channel	Exfiltrates via Naver email C2

Technique ID	Name	Description
T1033	System Owner/User Discovery	Identifies current user
T1547.001	Boot or Logon Autostart Execution: Registry Run Keys	Registry persistence
T1027	Obfuscated Files or Information	Uses obfuscation in dropper and payload

2.8.4 Execution Method

Delivered via malicious HWP (Hangul Word Processor) documents exploiting embedded EPS (Encapsulated PostScript) content vulnerabilities. The exploit dropper decodes and executes NavRAT which then authenticates to Naver email accounts controlled by the attacker to receive commands and send results.

2.8.5 Persistence Techniques

Windows Registry Run keys to survive system reboots.

2.8.6 Privilege Escalation

Operates under user-level privileges. No documented built-in escalation.

2.8.7 Defense Evasion

Uses legitimate South Korean web service (Naver) for C2 traffic, making all communications appear as normal email access; obfuscated exploit code in HWP EPS content; blends into South Korean operational network baseline.

2.8.8 Credential Access

Not directly documented for credential access; reconnaissance capabilities and screen capture can intercept credentials visually. Supports follow-on credential theft operations.

2.8.9 Discovery Techniques

System information collection, file and directory enumeration, running process listing, and user identity identification.

2.8.10 Lateral Movement

Remote shell capability enables operator-directed lateral movement; not directly documented with automated lateral movement functions.

2.8.11 Command & Control (C2)

Uniquely uses Naver (dominant South Korean web portal) email accounts for C2. The attacker sends commands via email to a Naver account accessed by the malware, and results are sent back to the same or another Naver account.

2.8.12 Exfiltration

Exfiltrates collected data (screenshots, files, system info) via Naver email accounts used for C2 communications.

2.8.13 Impact Analysis

Targeted espionage against South Korean government officials and organizations involved in North-South Korean diplomatic affairs; enables sustained surveillance and intelligence collection on sensitive political matters.

2.8.14 Indicators of Compromise (IOCs)

Malicious HWP documents with EPS content exploiting Hangul vulnerabilities; Naver email API/SMTP calls from non-mail processes; cmd.exe spawned by HWP process; screenshot files in temp directories; registry Run key creation.

2.8.15 Detection & Mitigation

Detection: Monitor Hangul Word Processor for spawning cmd.exe or other shell processes; Naver email API calls from non-browser/mail processes; screenshot activity outside normal applications; suspicious registry modifications.

Mitigation: Patch Hangul Word Processor to latest version; restrict or monitor cloud email access from sensitive workstations; email security controls; behavior-based EDR; user awareness training.

2.8.16 References & Sources

- <https://attack.mitre.org/software/S0247/>
- <https://blog.talosintelligence.com/2018/05/navrat.html>

Software 9: S0248 — yty

2.9.1 Name & Type

Field	Value
MITRE ATT&CK ID	S0248
Name	yty
Type	Malware (Modular RAT Framework)
Supported Platforms	Windows
Threat Actor	DoNot Team (APT-C-35 — South Asian origin)
ATT&CK Reference	https://attack.mitre.org/software/S0248/

2.9.2 Description

yty is a modular malware framework used by the DoNot Team (also known as APT-C-35), a threat actor with suspected South Asian origins primarily targeting government and military organizations in Pakistan, Bangladesh, Sri Lanka, and other South Asian countries. The yty framework consists of a core loader component and multiple downloadable plugin modules that extend its capabilities, supporting comprehensive espionage functions including keylogging, screenshot capture, file collection, and audio recording.

2.9.3 ATT&CK Techniques Used

Technique ID	Name	Description
T1056.001	Input Capture: Keylogging	Keylogging module via SetWindowsHookEx
T1113	Screen Capture	Screenshot capture plugin module
T1123	Audio Capture	Audio recording plugin module
T1005	Data from Local System	Collects files from local system
T1083	File and Directory Discovery	File and directory enumeration
T1057	Process Discovery	Lists running processes
T1082	System Information Discovery	Gathers system information
T1071.001	Application Layer Protocol: Web Protocols	HTTP/HTTPS C2 and plugin download
T1547.001	Boot or Logon Autostart Execution: Registry Run Keys	Registry persistence
T1566.001	Phishing: Spearphishing Attachment	Delivered via malicious documents
T1204.002	User Execution: Malicious File	Requires user to open malicious file

Technique ID	Name	Description
T1105	Ingress Tool Transfer	Downloads plugin modules from C2
T1041	Exfiltration Over C2 Channel	Exfiltrates collected data via C2
T1027	Obfuscated Files or Information	Obfuscated code and strings
T1036	Masquerading	Masquerades as legitimate applications

2.9.4 Execution Method

Delivered via spearphishing emails with malicious document attachments (Word, PDF, or CHM files). Upon execution, the yty core component installs itself and downloads additional plugin modules from the C2 server based on operator requirements.

2.9.5 Persistence Techniques

Registry Run keys; scheduled task creation; startup folder entries — multiple persistence mechanisms increase resilience.

2.9.6 Privilege Escalation

User-level execution for core component; modular design allows privilege escalation plugin loading if needed.

2.9.7 Defense Evasion

Obfuscated code limits static detection; modular architecture limits capability exposure (only loaded modules active at any time); masquerades as legitimate system applications.

2.9.8 Credential Access

Keylogging captures credentials as typed; screen capture intercepts on-screen credential entry. Provides rich credential harvesting capability.

2.9.9 Discovery Techniques

Comprehensive: file and directory enumeration, process listing, system information collection, network configuration discovery.

2.9.10 Lateral Movement

Intelligence gathered enables operator-directed lateral movement; modular design could accommodate lateral movement plugins.

2.9.11 Command & Control (C2)

HTTP/HTTPS communication for C2 commands and plugin download. Modular architecture allows dynamic capability expansion on demand by operators.

2.9.12 Exfiltration

Exfiltrates collected files, keystroke logs, screenshots, and audio recordings via HTTP/HTTPS C2 channel.

2.9.13 Impact Analysis

Long-term espionage against South Asian government and military targets; comprehensive surveillance covering audio, screen, keystrokes, and file collection; persistent strategic intelligence gathering.

2.9.14 Indicators of Compromise (IOCs)

Malicious document file execution; registry Run key or scheduled task persistence; HTTP/HTTPS C2 beaconing; plugin module download activity; keylogger log files in user temp directories; periodic screenshot files.

2.9.15 Detection & Mitigation

Detection: Monitor for malicious document macro/exploit execution; registry Run key and scheduled task changes; HTTP/HTTPS beaconing to unknown hosts; plugin download patterns; SetWindowsHookEx calls for keylogging.

Mitigation: Email security and attachment sandboxing; macro blocking via Group Policy; application whitelisting; EDR deployment; network monitoring for C2 patterns; patch document vulnerabilities promptly.

2.9.16 References & Sources

- <https://attack.mitre.org/software/S0248/>
- <https://www.welivesecurity.com/2018/05/22/next-level-of-donut-team/>
- <https://unit42.paloaltonetworks.com/updated-backconfig-malware-targeting-government-and-military-organizations/>

Software 10: S0249 — Gold Dragon

2.10.1 Name & Type

Field	Value
MITRE ATT&CK ID	S0249
Name	Gold Dragon
Type	Malware (Reconnaissance Implant / Validator)
Supported Platforms	Windows
Threat Actor	Lazarus Group (North Korea)
ATT&CK Reference	https://attack.mitre.org/software/S0249/

2.10.2 Description

Gold Dragon is a Korean-language file-based implant used by the Lazarus Group, first observed in campaigns targeting organizations connected to the 2018 PyeongChang Winter Olympics in South Korea. Used alongside Brave Prince and RunningRAT in the same campaign, Gold Dragon functions primarily as a first-stage reconnaissance and validation tool. It collects comprehensive system information and exfiltrates it to C2, allowing Lazarus Group operators to triage victims and decide whether to deploy further tooling.

2.10.3 ATT&CK Techniques Used

Technique ID	Name	Description
T1082	System Information Discovery	Comprehensive system information gathering
T1083	File and Directory Discovery	Enumerates files and directories
T1057	Process Discovery	Lists running processes
T1016	System Network Configuration Discovery	Gathers network configuration
T1033	System Owner/User Discovery	Identifies current user and context
T1071.001	Application Layer Protocol: Web Protocols	HTTP-based C2 communications
T1041	Exfiltration Over C2 Channel	Sends reconnaissance data to C2 for triage
T1566.001	Phishing: Spearphishing Attachment	Delivered via malicious documents
T1204.002	User Execution: Malicious File	Requires user to open malicious attachment

Technique ID	Name	Description
T1547.001	Boot or Logon Autostart Execution: Registry Run Keys	Registry Run key persistence
T1027	Obfuscated Files or Information	Obfuscated code for evasion
T1059.003	Command and Scripting Interpreter: Windows Command Shell	CMD execution

2.10.4 Execution Method

Delivered via malicious Korean-language lure documents related to the PyeongChang Winter Olympics. Upon execution, Gold Dragon installs registry persistence and begins comprehensive system reconnaissance, immediately reporting findings to the C2 server for operator triage.

2.10.5 Persistence Techniques

Windows Registry Run keys for persistence across system reboots.

2.10.6 Privilege Escalation

User-level execution. No documented built-in privilege escalation.

2.10.7 Defense Evasion

Korean-language lure documents blend naturally with target environment (South Korea); validates victim before deploying further payloads, limiting broader exposure; obfuscated code.

2.10.8 Credential Access

Not directly documented; serves as validator/reconnaissance tool to inform follow-on credential theft and intrusion operations.

2.10.9 Discovery Techniques

Extensive first-stage reconnaissance: system information, file/directory enumeration, process listing, network configuration, user and owner identification — all sent to C2 for operator triage decision-making.

2.10.10 Lateral Movement

Not directly; provides comprehensive reconnaissance data enabling operators to plan lateral movement strategy.

2.10.11 Command & Control (C2)

HTTP-based C2 communication. Exfiltrates collected system reconnaissance data to attacker-controlled server via HTTP POST for operator triage.

2.10.12 Exfiltration

Exfiltrates system reconnaissance data to C2 server via HTTP immediately after collection.

2.10.13 Impact Analysis

Geopolitically motivated intelligence collection targeting organizations connected to the 2018 Winter Olympics; enables Lazarus Group to triage victims and focus resources on highest-value targets for follow-on operations.

2.10.14 Indicators of Compromise (IOCs)

Korean-language Olympic-themed lure documents; HTTP POST requests with system reconnaissance data; registry Run key persistence entries; process execution from unusual paths; code artifact overlap with Brave Prince and RunningRAT.

2.10.15 Detection & Mitigation

Detection: Suspicious document execution followed by immediate HTTP POSTing of system data; registry Run key creation by document processes; correlation with Brave Prince/RunningRAT IOCs; Lazarus Group network indicators.

Mitigation: Email security and document sandbox analysis; patch document vulnerabilities; EDR deployment; network monitoring for immediate post-execution data exfiltration; Lazarus Group threat intelligence feeds.

2.10.16 References & Sources

- <https://attack.mitre.org/software/S0249/>
- <https://blog.trendmicro.com/trendlabs-security-intelligence/lazarus-campaign-pyeongchang-winter-olympics/>
- <https://www.mcafee.com/blogs/other-blogs/mcafee-labs/gold-dragon-widens-olympics-malware-attacks-adds-langdownloader-gold-dragon/>